

JWT Forge

Bối cảnh (Context)

Hệ thống JWT mới được thiết kế chuẩn xác với thuật toán bảo mật bất đối xứng RS256 (có Public Key và Private Key). Private Key được giữ trên máy chủ vô cùng an toàn, còn Public Key được cấp cho các vệ tinh để kiểm tra chữ ký token. Hệ thống lấy Public Key từ một đường dẫn cấu hình sẵn trong Header của token (tham số `jku`).

Kiến trúc hoàn hảo, nhưng liệu quy trình nạp Public Key có an toàn tuyệt đối?

Mục tiêu (Objective)

- **Nhiệm vụ:** Tự tạo ra một token quản trị hợp lệ, lừa máy chủ phải chấp nhận nó.
- **Vấn đề / Lỗ hổng: JWT Header Injection (JKU/KID Spoofing).** Trong Header của JWT, tham số `jku` (JWK Set URL) chỉ định nơi tải Public Key. Nếu máy chủ không kiểm tra kỹ đường dẫn này (whitelisting), bạn có thể đổi `jku` trở về máy chủ của bạn, tự sinh ra một cặp Private/Public Key của riêng mình, ký JWT bằng Private Key của bạn, và bắt máy chủ phải xác thực chữ ký bằng Public Key của bạn.
- **Flag:** Token hợp lệ giúp truy cập vào khu vực Admin.

Gợi ý (Hints)

- Viết một file JWKS (JSON Web Key Set) chứa thông tin khóa công khai của bạn, và host nó trên một server cá nhân.
- Sửa Header của JWT trở tham số `jku` về file của bạn.